

MedTech Cloud Security Assessment

AWS Security & Compliance Review

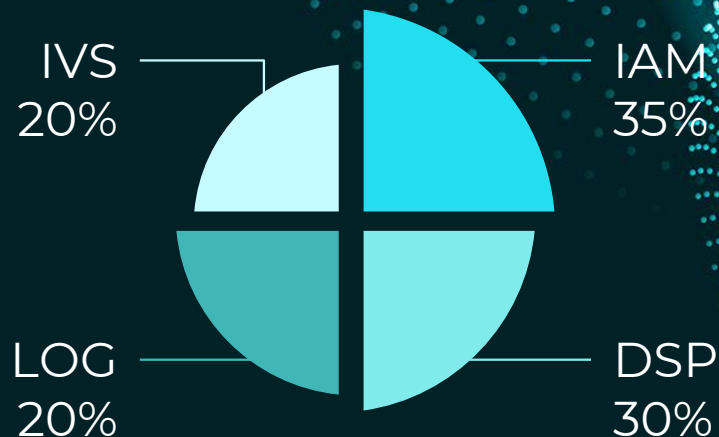
Adarsh Rai, Anupam Rajeev, Chandan Vedvyas, Kush Patel

Executive Summary

Security maturity is developing but not yet compliant with HIPAA or CCM standards.

Critical risks identified in identity management, PHI data protection, and logging.

Foundational controls exist, but lack of encryption, monitoring, and access governance creates systemic exposure.



Compliance Status - Partial alignment

- CSA CCM v4.0: 60% implementation maturity.
- HIPAA §164.312: Gaps in audit, encryption, and access safeguards.
- AWS Well-Architected Framework: Missing automation and detection controls.

Assessment Methodology

CCM + HIPAA + AWS WAF



IAM

Identity and Access
Management



DSP

Data Security &
Privacy



LOG

Logging &
Monitoring



IVS

Infrastructure &
Virtualization
Security

Assessment Approach

- AWS CLI evidence collection
- Console configuration review
- HIPAA compliance mapping
- ~20 CCM control evaluated

IAM Findings

Control ID	Finding	Risk Level	HIPAA Impact
IAM-01: User Access Management	MFA disabled for all IAM users (AccountMFAEnabled = 0).	Critical	Violates §164.312(a)(2)(i) – Unique User Identification and §164.312(d) – Authentication of Users.
IAM-01 / Root Account Protection	Root account console enabled without MFA.	Critical	Total account compromise risk; full administrative control exposure.
IAM-03: Authentication Strength (Password Policy)	No account-level password policy configured (NoSuchEntity error).	High	Weak passwords undermine user identity integrity and audit traceability.
IAM-05: Access Key Management	Long-lived access keys active for medtech-assessment-student; one unused.	High	Shared or unrotated credentials risk unauthorized PHI access.

IAM Finding Evidences

```
C:\Users\cvedavya>aws iam get-account-summary
```

GetAccountSummary	
SummaryMap	
AccessKeysPerUserQuota	2
AccountAccessKeysPresent	0
AccountMFAEnabled	0
AccountPasswordPresent	0

	A	B	H
1	user	arn	mfa_active
2	<root_account>	arn:aws:iam::658910374581:root	FALSE
3	medtech-assessment-admin	arn:aws:iam::658910374581:user/medtech-assessment-admin	FALSE
4	medtech-assessment-developer	arn:aws:iam::658910374581:user/medtech-assessment-developer	FALSE
5	medtech-assessment-student	arn:aws:iam::658910374581:user/medtech-assessment-student	FALSE
6	Terraform	arn:aws:iam::658910374581:user/Terraform	FALSE

Users (4) [Info](#)

An IAM user is an identity with long-term credentials that is used to interact with AWS in an account.

☐	User name	Path	Group	Last activity	MFA
☐	medtech-assessment-admin	/	0	-	-
☐	medtech-assessment-developer	/	0	-	-
☐	medtech-assessment-student	/	0	✓ 8 minutes ago	-
☐	Terraform	/	0	✓ 7 days ago	-

IAM Dashboard [Info](#)

Security recommendations 1



Add MFA for yourself

Add multi-factor authentication (MFA) for yourself to improve security for this account.

[Add MFA](#)

Your user, medtech-assessment-student, does not have any active access keys that have been unused for more than a year.

Deactivating or deleting unused access keys improves security.

S3 Buckets DSP Findings

Critical – Patient Records (PHI)

Sensitive information is stored without KMS encryption, versioning, or access logging. Violates HIPAA's requirements for encryption and integrity, creating the highest compliance and breach risk.

High – CloudTrail Audit Logs

Audit logs lack immutability, versioning, and defined retention. In a security incident, this would prevent reliable forensic investigation

Medium – AI Training and System Logs

AI and log buckets are unencrypted, unclassified, and lack lifecycle management.

Bucket Name	Tags	Encryption	Versioning	Logging	Object Lock	Block Public Access	ACL	Risk
medtech-assessment-patient-records	PHI, HIPAA	Default SSE-S3, No KMS	Disabled	Disabled	Disabled	On	On, Owner enforced	Critical
medtech-assessment-logs-vqkld7n	Logs	Default SSE-S3, No KMS	Disabled	Disabled	Disabled	On	On, Owner enforced	Medium
medtech-assessment-cloudtrail-vqkld7n	Assessment	Default SSE-S3, No KMS	Disabled	Disabled	Disabled	On	On, Custom	High
medtech-assessment-ai-training-vqkld7n	Training	Default SSE-S3, No KMS	Disabled	Disabled	Disabled	On	On, Custom	Medium
medtech-assessment-public-data-vqkld7n	Public	Default SSE-S3, No KMS	Disabled	Disabled	Disabled	Off	On, Custom	Low

DSP - Compliance & AWS Remediations

Patient Records – Critical

SSE-S3 only; versioning, logging, Object Lock disabled.

Enable SSE-KMS, Versioning, Object Lock, 6-yr retention.
HIPAA: §164.312(a)(2)(iv)(I) CCM: DSP-03, DSP-06, DSP-08

CloudTrail Logs – High

No immutability or lifecycle; SSE-S3 only.

Add Object Lock, KMS, retention ≥ 6 yrs; restrict write access.
HIPAA: §164.312(b) CCM: LOG-01, DSP-06

AI Training Data – Medium

Unclassified, unencrypted (SSE-S3); no versioning/logging.

Apply SSE-KMS, Versioning, Classification Tags, VPC isolation.
HIPAA: §164.312(a)(2)(iv), CCM: DSP-02, DSP-03
OWASP LLM: A1, A2

Default encryption [Info](#)

Server-side encryption is automatically applied to new objects stored in this bucket.

Encryption type [Info](#)

Server-side encryption with Amazon S3 managed keys (SSE-S3)

Bucket Key

When KMS encryption is used to encrypt new objects in this bucket, the bucket key is used. Disabled

Object Lock

Store objects using a write-once-read-many (WORM) model. Object Lock works only in versioned buckets. [Learn more](#)

Object Lock

Disabled

Bucket Versioning

Versioning is a means of keeping multiple versions of an object in your Amazon S3 bucket. With versioning enabled, you can restore previous versions of an object.

Bucket Versioning

Suspended

Server access logging

Log requests for access to your bucket. Use [CloudWatch](#) to monitor bucket access logs.

Server access logging

Disabled

AWS CloudTrail data events

[Info](#) You can view and configure CloudTrail data events for this bucket.

IVS

Infrastructure & Virtualization Security

Business Impact:

1. Hackers can break into web servers
2. Access to all private resources
3. Patient data breach, ransomware, or system compromise
4. Unavailability (Brute force from SSH)
5. Penetration tests flag - immediately
6. Major compliance violation for SOC 2, PCI-DSS, HITRUST

Default VPC

CCM: IVS-08

(Network Architecture Documentation)

SSH bastion host CCM: IVS-03 (Network Security)

CRITICAL

i-0b88cb59e34475df4 (medtech-assessment-bastion)

Details | Status and alarms | Monitoring | **Security** | Networking | Storage | Tags

▼ Security details

IAM Role: [medtech-assessment-ec2-role](#) | Owner ID: 658910374581 | Launch time: Sun Sep 28 2025 13:38:15 GMT-0400 (Eastern Daylight Time)

Security groups: [sg-009a543e1847994c3 \(medtech-assessment-web-sg\)](#)

▼ Inbound rules

Name	Security group rule ID	Port range	Protocol	Source	Security groups	Description
-	sgr-0ca3521430bca7a94	443	TCP	0.0.0.0/0	medtech-assessment-web-sg	HTTPS from anywhere
-	sgr-064f7c4ef7043685e	80	TCP	0.0.0.0/0	medtech-assessment-web-sg	HTTP from anywhere
-	sgr-012f2f466da20bec	22	TCP	0.0.0.0/0	medtech-assessment-web-sg	SSH from anywhere

sg-0b021dee129ab4526 - default

Details | **Inbound rules** | Outbound rules | Sharing - new | VPC associations - new | Tags

HIGH

Inbound rules (1)

Name	Security group rule ID	IP version	Type	Protocol	Port range	Source
-	sgr-0d63fc072e88b9b4b	-	All traffic	All	All	sg-0b021dee129ab4526

Database Exposed to Internet

CCM: IVS-03 (Network Security) &
DSP-04 (Data Protection)

Business Impact:

- HIPAA violation ePHI accessible from public internet
- Direct path to patient medical records if credentials compromised
- Database can be targeted for:
 - * SQL injection attacks
 - * Brute force password attacks
 - * Ransomware encryption
 - * Data exfiltration

IVS Infrastructure & Virtualization Security

CRITICAL

The screenshot displays the AWS Management Console for Security Groups. The top section shows a list of security groups, with 'medtech-assessment-database-sg' selected. Below this, the 'Inbound rules' tab is active, showing a single rule with the following details:

Name	Security group rule ID	IP version	Type	Protocol	Port range	Source
-	sg-0b1dfa7d1705e6f38	IPv4	MYSQL/Aurora	TCP	3306	0.0.0.0/0

The entire 'Inbound rules' section is highlighted with a red rectangle. The console interface includes search bars, filters, and navigation tabs at the top and bottom of the rule list.

LOGGING AND MONITORING

Critical – Real time monitoring

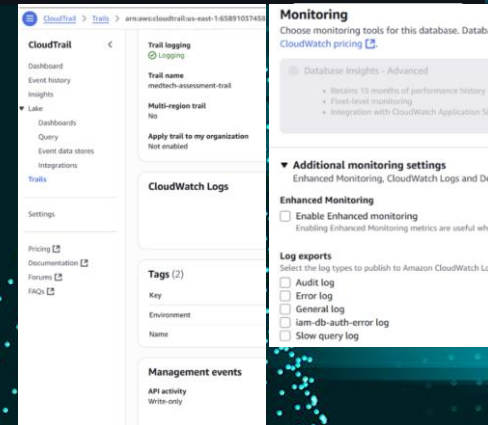
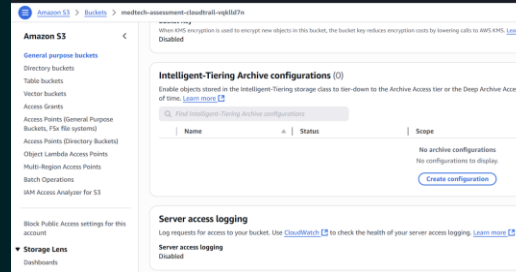
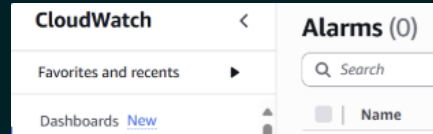
There is no configuration in place for real time monitoring or alerting of security events. Services such as Amazon GuardDuty, AWS Security Hub and CloudWatch alarms are not provisioned.

High – Centralized Logging

Centralized collection and Generation of Logs - Disabled for key services like RDS, S3, EC2, load balancers and lambda functions.

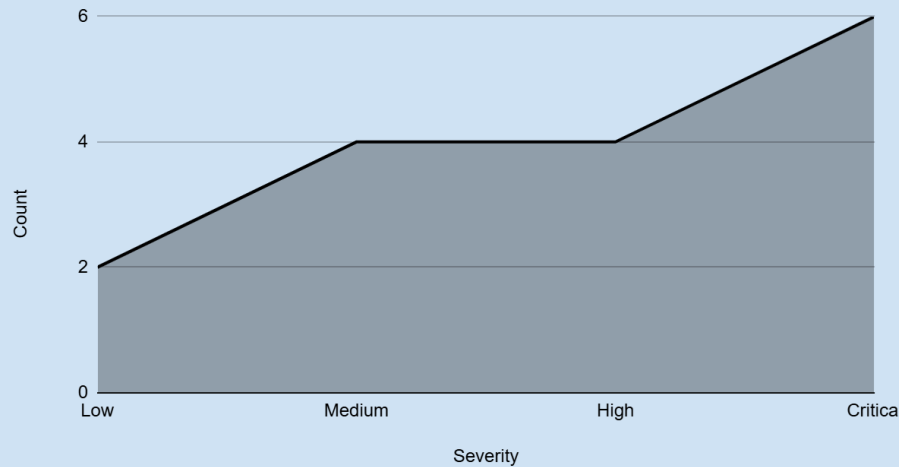
Medium– CloudTrail

CloudTrail is configured to log only write events. Log file validation is also disabled.



Risk & Priority Distribution

Count vs. Severity



TOP PRIORITIES

IVS - DATABASE EXPOSED TO INTERNET

IVS - SSH ACCESS EXPOSED TO INTERNET

IAM - MFA ENFORCEMENT

IAM - ROOT ACCOUNT WITHOUT MFA

DSP - UNENCRYPTED AND NON AUDITABLE PHI STORAGE

LOG - NO REAL TIME MONITORING

Remediation Roadmap - Critical Actions

 Immediate Actions (24-48 Hours)

#	Action	AWS Implementation	Owner
1	Disable RDS public access	RDS Console → Modify → Publicly accessible: No	DevOps
2	Restrict RDS security group	EC2 → SG → db-sg → Remove 0.0.0.0/0	Security
3	Enable root MFA	IAM → Root user → Enable MFA	CISO
4	Delete unused access keys	IAM → Users → Security credentials	Security
5	Enable S3 KMS encryption	S3 → patient-records → Default encryption: KMS	DevOps

 **Critical:** Execute items 1-3 immediately. Emergency change control required within 2 hours.

Remediation Roadmap - Critical Actions

Short-term fixes (1-2 Weeks)

Action	AWS Implementation	Priority
Enable GuardDuty	GuardDuty → Get Started → Enable	HIGH
Enable Security Hub	Security Hub → Enable → AWS Foundational	HIGH
Enable S3 versioning	S3 → Properties → Versioning + MFA Delete	HIGH
Enable S3 logging	S3 → Properties → Server access logging	HIGH
Password policy	IAM → Account settings → Password policy	MED

Long-Term Improvements (1-3 Months)

IAM Role Migration

|

Object Lock (WORM)

|

Network ACLs

|

SIEM Integration

Compliance Mapping

HIPAA Considerations

- Execute and maintain AWS BAA, document shared-responsibility boundaries
- Perform risk analysis and risk management; track remediation with owners and dates
- Enforce least privilege and unique user IDs; require MFA for privileged access

AWS Well-Architected gaps

- Security: missing MFA on root and weak IAM hygiene, limited detection, incomplete logging, inconsistent data protection
- Reliability: incomplete backups/versioning, limited immutability, unclear DR objectives and testing cadence
- Operational Excellence: undefined alert owners and runbooks, limited metrics and alarm thresholds, weak change tracking

Regulatory implications

- Increased exposure to OCR enforcement for Security Rule deficiencies and inadequate logging
- Contractual and liability risk without a current BAA and documented risk-management evidence
- Incident investigations slowed by incomplete audit trails and lack of log integrity
- Expected fines can cost upwards of \$4 Million + reputational damages to Medtech

TOP 4 RECOMMENDATIONS

Harden IAM

Enforce MFA and strong password policies

Encrypt Data

Set default KMS encryption for S3 & RDS

Network Segmentation

Disable public database access & apply ACLs

Monitoring and Logging

SIEM Integration, Enable GuardDuty & Security Hub



\$2,400
~120 Hrs

Full Regulatory Compliance
Stronger Operational Security

Thank you!

